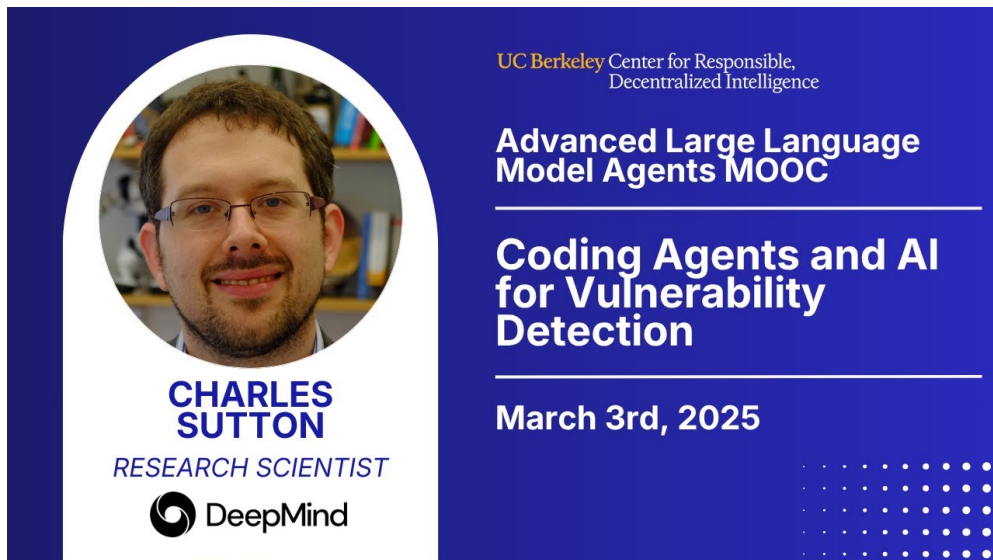


课程笔记

[LLM Agents SP25] Coding Agents AI Vulnerability Detection —Charles Sutton

基于公开课程资料整理

2025



视频作者/频道: Berkeley RDI

发布日期: 2025

视频时长: 约 60 分钟

项目主页: <https://github.com/hqh1025/ai-course-notes>

目录

1	引言	2
2	代码生成评估的演进	2
2.1	早期评估: MBPP 与 HumanEval	2
2.2	SWE-Bench: 真实软件工程评估	2
3	AI 与计算机安全	2
3.1	安全漏洞的类型	2
3.2	AI 在安全中的应用	2
4	Project Naptime / Big Sleep: LLM Agent 发现真实漏洞	3
5	总结与延伸	3
5.1	拓展阅读	3

1 引言

本讲由 Google DeepMind 的 Charles Sutton 主讲，分为三部分：编程 Agent 概述、AI 在计算机安全中的应用、以及用 LLM Agent 发现安全漏洞。

LLM Agent 的实质定义

LLM Agent = 多轮 LLM + 工具使用 (React 循环)。关键优势：

- 动态计算时间：困难问题获得更多思考
- 外部工具：运行代码、查看输出、迭代修正
- 假设检验：提出假设、测试、修正

2 代码生成评估的演进

2.1 早期评估：MBPP 与 HumanEval

自然语言 → 短 Python 函数 (5–10 行)，使用 Pass@K 指标。2021 年令人惊叹，现在已成为“代码评估的 MNIST”。

好的评估设计原则

1. 自动化正确性检查（而非人工评判）
2. 难度适中：不在地板也不在天花板
3. 未被泄露到训练数据中
4. 与生产部署场景匹配

2.2 SWE-Bench：真实软件工程评估

SWE-Bench 的设计

从 GitHub 真实 Issue 和 Pull Request 中提取任务：给定 Issue 描述和代码库，Agent 需生成修复补丁。通过项目已有的测试套件自动验证。

3 AI 与计算机安全

3.1 安全漏洞的类型

主要关注内存安全漏洞（缓冲区溢出、释放后使用等）和逻辑漏洞。

3.2 AI 在安全中的应用

- 模糊测试增强：用 LLM 生成更有针对性的测试输入
- 漏洞检测：分析代码模式识别潜在漏洞

- **漏洞修复**：自动生成修复补丁

4 Project Naptime / Big Sleep: LLM Agent 发现真实漏洞

Big Sleep 项目

Google DeepMind 与 Project Zero 合作，用 LLM Agent 发现真实世界软件中的安全漏洞。Agent 使用代码浏览、搜索、运行调试器等工具，在真实开源项目中发现了此前未知的漏洞。

安全领域的特殊考量

AI 在安全领域是“双刃剑”：可用于防御（漏洞检测和修复），也可能被滥用于攻击（自动化漏洞发现和利用）。

5 总结与延伸

编程 Agent 正从简单代码补全走向完整的软件工程任务。AI 在计算机安全领域具有巨大潜力，但需要负责任地使用。LLM Agent 的工具使用能力使其成为安全研究的有力工具。

5.1 拓展阅读

- SWE-Bench / SWE-Agent
- Project Naptime / Big Sleep (Google DeepMind)
- OSS-Fuzz: Google 的开源模糊测试基础设施